HONEYNET ADAPTATIVO CON VERIFICACIÓN AUTOMÁTICA DE SUPERFICIE DE ATAQUE

ANTEPROYECTO

Adrián Mirabent Landero
Administración de Sistemas Informáticos en Red.
IES La Marisma. Huelva

Sumario

TÍTULO DEL PROYECTO....3
DESCRIPCIÓN Y OBJETIVOS....3
MÉTODOS Y FASES DE TRABAJO....5
MEDIOS Y RECURSOS NECESARIOS....5
BIBLIOGRAFÍA BÁSICA....6

TÍTULO DEL PROYECTO

Honeynet adaptativo con verificación automática de superficie de ataque.

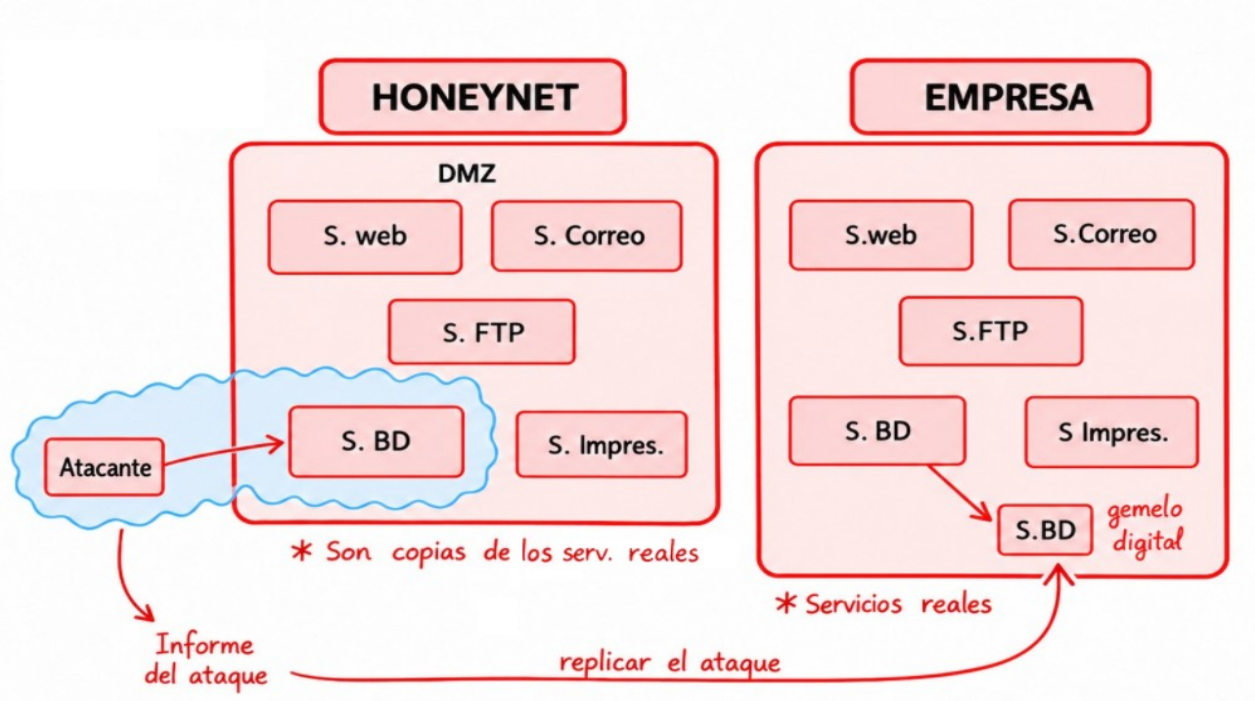
DESCRIPCIÓN Y OBJETIVOS

Este proyecto es un cluster de honeypot dentro de una DMZ, aprovisionado como infraestructura como código (Terraform), que no se limita a detectar intentos de intrusión.

Cada honeypot contendrá una copia de uno de los servicios de la empresa que queremos proteger (Servicio Web, servicio FTP, etc).

A diferencia de una trampa tradicional que se limita a dar un aviso, este sistema registra y aprende exactamente como actúa el atacante, analizando las herramientas que usa y el orden de sus acciones para crear una huella de su comportamiento.

Una vez obtenida esta información, el sistema la utiliza para comprobar automáticamente si esas mismas técnicas de ataque funcionarían contra un gemelo digital, que es una réplica exacta de uno de los servicios reales de la empresa a proteger.



Por ejemplo: Si se detecta un ataque en el servicio de base de datos de nuestro honeynet, nuestro sistema registra el ataque y nos proporciona información sobre él; información que posteriormente usaremos para replicar el ataque contra un gemelo digital de nuestro servicio de base de datos real de la empresa. Si el ataque replicado es efectivo y pone en riesgo ese gemelo digital, se debe proceder a parchear la vulnerabilidad encontrada en el servicio de la empresa real.

Hoy en día detectar un ataque y bloquear la dirección IP del atacante es insuficiente; por este motivo el proyecto se enfoca en:

- Identificar al atacante por su propia forma de comportarse y sus técnicas, algo mucho más difícil de disfrazar o cambiar que una simple dirección IP.
- Ir más allá de la simple instalación de programas de seguridad que ya existen, desarrollando un sistema de integración propio que conecte la trampa con la evaluación de riesgos.

El objetivo del proyecto es construir, pieza a pieza, un sistema que convierta los ataques reales que reciba en información útil para proteger los activos reales de la empresa.

Los 3 objetivos fundamentales que se quieren conseguir con este proyecto son:

1. Conseguir que toda la estructura de la red señuelo (honeynet) se despliegue de forma automatizada con Terraform.
2. Generar de forma automática un informe de ataques basado en evidencias reales, indicando exactamente las puertas o debilidades hay que arreglar en la empresa real.
3. Poner en práctica y unificar todos los conocimientos del ciclo superior de ASIR, integrando la gestión de redes seguras, sistemas operativos, bases de datos, automatización y análisis de vulnerabilidades.

MÉTODOS Y FASES DE TRABAJO

Sprint	Foco ampliado	Entregable clave
Sprint 1 (RA1)	Viabilidad, justificación del alcance ampliado y diseño conceptual de los puntos anteriores.	Memoria v1.0 + PoC mínima (un honeypot respondiendo).
Sprint 2 (RA2)	Diseño detallado por capa: módulos Terraform, base de datos, lógica del modus operandi de los ataques y de inicio de escaneo ante un ataque.	Memoria v2.0 + Topología de red y servicios base levantados.
Sprint 3 (RA3)	Construcción incremental: honeynet operativa, pipeline para unificar los logs, primeros patrones de los ataques. Panel, producto mínimo viable (MVP).	Memoria v3.0 + Demo de ataque simulado detectado y mostrado en el panel MVP.
Sprint 4 (RA4)	Verificación automática contra el gemelo digital, respuesta adaptativa, pruebas de robustez y de evasión por VPN.	Memoria v4.0 final + tag v1.0.0 en repositorio en GitHub.

MEDIOS Y RECURSOS NECESARIOS

Para construir y automatizar este sistema, el proyecto se apoyará en herramientas profesionales de alto estándar en el sector, conectadas mediante software desarrollado por nosotros mismos:

- Infraestructura y automatización: Usamos Terraform para aprovisionar junto a contenedores Docker y scripts para desplegar la red señuelo de forma automática (IaaC Infraestructure as a Code)
- Honeypot: Usaremos un programa específico, Cowrie.
- Recolección de datos: Para recoger toda la actividad de los atacantes, utilizaremos recolectores de registros como rsyslog o filebeat.

- Análisis y cerebro del sistema: Desarrollaremos un motor propio en Python, que analizará el comportamiento capturado y lo cruzará con bases de datos de ciberseguridad.
- Verificación: Para comprobar automáticamente si el ataque funcionaría en nuestra réplica de la empresa, usaremos escáneres de vulnerabilidad como nmap y OpenVAS.
- Visualización y bloqueo: Los resultados se mostrarán en un panel gráfico de una aplicación web propia (php), mientras que para bloquear y reaccionar a los ataques combinaremos herramientas como Fail2Ban con nuestro propio programa de control.

BIBLIOGRAFÍA BÁSICA

Infraestructura y automatización:

https://www.arsys.es/blog/que-es-terraform-y-cuales-son-sus-ventajas

https://www.redhat.com/es/topics/containers/what-is-docker

Honeypots:

https://latam.kaspersky.com/resource-center/threats/what-is-a-honeypot

https://cowrie.org/

Recolección de datos:

https://www.rsyslog.com/

https://keepcoding.io/blog/que-es-filebeat/

Análisis y cerebro del sistema:

https://www.python.org/

Verificación:

https://nmap.org/

https://openvas.org/

Visualización y bloqueo:

https://www.php.net/downloads.php

https://www.arsys.es/blog/instalar-fail2ban